Enterprise Zero Trust Security Architecture

HL-CYB-001 | Four-week cybersecurity engineering assignment

Status: **PLANNED**. Lab controls: **NOT TESTED**.

1. Project Overview

Purple Eye, a fictional organization, needs an analyst to read reports, an engineer to read maintenance instructions and an unassigned user to be denied access. A separate administrator manages the lab.

Build an isolated lab that demonstrates these decisions, remote access and application recovery using synthetic people and data. Apply Zero Trust: check identity and permission for each resource; network membership alone grants no access.

2. Learning Objectives

- Build three network zones and protect administration.
- Verify permitted, denied, remote and revoked access.
- Investigate security events, automate one operation and restore a backup.
- Present measured results and limitations with clear evidence.

3. What You Will Build

Infrastructure and identities

- One Proxmox host; four virtual machines (VMs): OPNsense firewall, Windows Server, Windows endpoint and Linux application server.
- Three zones: **Management, Corporate and Restricted**.
- Three synthetic standard users, three role groups and one separate privileged administrator.
- Active Directory (AD), Domain Name System (DNS) and Group Policy for Windows accounts and settings.
- One simple certificate authority (CA), one HTTPS application certificate for encrypted web access and Tailscale-only remote access.

Application identity: AD manages Windows lab accounts. The application uses separate test accounts, distinct passwords and manually assigned roles. Removing an application role must deny further access. Enterprise single sign-on is excluded.

Readiness: Use existing and ordered hardware. Confirm availability, compatibility, current data and services, backup and recovery readiness. Preserve the original Windows disk, data and services. Ordered equipment is not assumed delivered, installed or validated. Start the four weeks after readiness approval.

Safety boundaries

- Use lab identities, credentials and synthetic data only. No connectivity, trust or synchronization with home or production; no corporate Microsoft 365, PE-DAP, customer data, corporate website testing or hosting integration.
- Start offline. Online access requires approved independent isolation. Inspect protected settings passively; use lab-owned mock targets, never probes of home or production systems.
- Obtain owner approval before disk formatting, Proxmox installation, network changes or other destructive or high-risk work. Follow the Lab Guide's detailed controls.

Excluded

- Extra VMs or zones, high availability, clustering and additional remote providers.
- Multi-level CA and enterprise timing, retention or recovery targets.

4. Project Requirements

FWR labels a requirement; FWT labels its matching test. Keep these labels in your records and complete every mandatory subcheck.

ID	Required result	Test
FWR-01	Keep lab networks, trust, credentials and data separate from home and production; verify isolation by configuration review and a lab-owned mock boundary.	FWT-01
FWR-02	Run one host, four VMs and three zones; deny unlisted flows, restrict administration, retain console recovery and confirm measured capacity fits.	FWT-02
FWR-03	Create separate AD with three standard users, three role groups and one privileged admin. Pass six application allow/deny cases and revoke access.	FWT-03
FWR-04	Use supported Windows and Linux systems, enabled host firewalls, recorded updates and separate standard-user and administrator rights.	FWT-04
FWR-05	Sign one HTTPS application certificate with one CA; verify hostname, trust, validity and untrusted-client rejection.	FWT-05
FWR-06	Allow lab-only Tailscale access solely to app.ad.lab.test over HTTPS. Demonstrate permitted, denied and revoked access.	FWT-06
FWR-07	Record five security events from two or three relevant log sources and investigate one denied-access event.	FWT-07
FWR-08	Complete one useful PowerShell or Python operation. Repeat it safely with no unintended changes.	FWT-08
FWR-09	Restore the agreed application scope from one encrypted backup stored away from the host; record actual recovery time, data checks and exclusions.	FWT-09
FWR-10	Link requirements and tests to reviewed evidence; submit files and sanitized GitHub work. Separate engineering verification from owner acceptance.	FWT-10

5. Required Deliverables

The Office templates are **planned and not yet available**. Complete these five files when released. Keep working copies and raw evidence private; submit reviewed summaries under `docs/deliverables/`.

Filename	What to record
01-Lab-Environment-and-Architecture.xlsx	Readiness, topology, capacity and flows (FWR-01, FWR-02).
02-Identity-and-Zero-Trust-Implementation.docx	Accounts, endpoints, roles, HTTPS and Tailscale (FWR-03, FWR-04, FWR-05, FWR-06).
03-Security-Monitoring-and-Testing.xlsx	Events, investigation, tests, automation and restore (FWR-07, FWR-08, FWR-09, FWR-10).
04-Troubleshooting-and-Lessons.xlsx	Problems, diagnosis, fixes, retests and lessons (FWR-10).
05-Final-Project-Submission.docx	Results, evidence, rubric, limits and acceptance (FWR-10).

6. Four-Week Implementation Plan

Follow the Lab Implementation Guide. Meet each phase checkpoint and obtain the required approvals.

Week	Phase and activities	Checkpoint
1	1. Infrastructure and Network: readiness, approved host and firewall installation and three zones.	Isolation, network policy and recovery access verified.
2	2. Identity and Endpoint Security: AD accounts, groups and endpoint baselines.	Standard logon, endpoint controls and separate privileges verified.
2-3	3. Zero Trust Access Controls: HTTPS, application roles and scoped Tailscale.	Six access cases, application revocation and remote allowed, denied and revoked access verified.
3-4	4. Monitoring, Automation and Recovery: events, denial investigation, one operation, backup and restore.	Five events, investigation, safe repetition and successful restore recorded.
4	5. Validation and Final Submission: tests, defect resolution and reviewed submission.	All ten tests have evidence; submission is ready for owner review.

Allow 8-12 focused hours weekly after readiness approval. Prerequisite delays move dates, never safety boundaries.

7. Evaluation Criteria

Grade demonstrated results, not plans alone. All mandatory subchecks must pass. Record actual results and failures; mark unexecuted checks **NOT TESTED**. Support denials with a working control and second policy/log observation. Critical isolation or security failures block acceptance regardless of score.

Assessment area	Points	Evidence for full credit
Infrastructure and Network Security	25	Working four-VM lab, three zones, protected administration and isolation and default-deny evidence.
Identity and Access Controls	25	AD and endpoint controls, six role cases, access revocation, HTTPS and restricted Tailscale.
Security Monitoring and Operations	20	Five events, one explained denial and safely repeatable automation.
Testing and Recovery	20	Complete test records, second observations and a successful restore with measured limits.
Documentation and Final Submission	10	Five clear submissions, traceable sanitized evidence and accurate results and limitations.

Total: 100 points. Owner user acceptance testing (UAT) is a separate, explicit decision. See the Acceptance Criteria; a passing documentation check does not demonstrate a working lab.

8. References

- NIST SP 800-207: Zero Trust Architecture - resource-focused access principles.
- Lab Implementation Guide and Architecture - procedures, boundaries and sizing.
- Glossary - terminology used in the project.